

Ультимативное руководство по AS-REP Roasting: Вскрываем уязвимости Kerberos pre-authentication

 redsec.by/article/ultimativnoe-rukovodstvo-po-as-rep-roasting-vskryvaem-uyazvimosti-kerberos-pre-authentication

Red Teams | 24 апреля 2026



В современных корпоративных сетях Active Directory (AD) остается главным механизмом аутентификации и авторизации. Несмотря на то, что протокол Kerberos считается надежным стандартом, легаси-конфигурации и ошибки администрирования регулярно открывают двери для компрометации целых доменов. Одной из таких критических, но часто недооцениваемых техник является **AS-REP Roasting (ASREPRoasting)**.

В данном техническом руководстве мы, опираясь на опыт Red Team и архитектуры безопасности, разберем механику атаки, при которой злоумышленник извлекает хэши паролей пользователей без необходимости взаимодействовать с целевой системой или вызывать блокировку учетной записи. Эта техника формализована в матрице **MITRE ATT&CK** как под-техника **T1558.004 («Steal or Forge Kerberos Tickets: AS-REP Roasting»)** и является классическим вектором в тактике *Credential Access*.

Важно: Данный материал предназначен исключительно для специалистов по информационной безопасности, системных администраторов и пентестеров. Все

приведенные примеры команд и скриптов должны использоваться только в авторизованных аудитах безопасности.

Анатомия протокола Kerberos и механизм AS-обмена

Чтобы понять природу AS-REP Roasting, необходимо глубоко погрузиться в механику работы Kerberos. В среде AD протокол Kerberos использует **KDC (Key Distribution Center)**, который традиционно развертывается на каждом контроллере домена (Domain Controller, DC). Логически KDC разделен на два ключевых компонента:

- **Authentication Service (AS)** — отвечает за первичную аутентификацию и выдачу билета на получение билетов (TGT — Ticket Granting Ticket).
- **Ticket Granting Service (TGS)** — обрабатывает запросы на доступ к конкретным службам, выдавая сервисные билеты (Service Tickets).

Легитимный поток аутентификации (с включенной Pre-Auth)

В защищенной (дефолтной) конфигурации процесс первичной аутентификации выглядит следующим образом:

1. **AS-REQ (Первичный запрос):** Клиент отправляет запрос к AS для получения TGT. Если для учетной записи включена предварительная аутентификация (pre-authentication), в этот запрос включается структура PA-ENC-TIMESTAMP (временная метка, зашифрованная долгосрочным ключом пользователя — то есть хэшем его пароля).
2. **Проверка на стороне KDC:** KDC извлекает хэш пароля пользователя из базы NTDS.dit, расшифровывает временную метку. Если время совпадает (с учетом допустимого рассинхрона, обычно 5 минут), KDC убеждается, что клиент действительно знает пароль.

Практика: Если клиент отправляет первый запрос без временной метки, KDC отклоняет его, возвращая ошибку KRB-ERROR KRB5KDC_ERR_PREAUTH_REQUIRED. После этого клиент автоматически повторяет запрос (Повторный AS-REQ), уже добавляя зашифрованную метку.

3. **AS-REP (Ответ сервера):** Убедившись в подлинности клиента, KDC формирует ответ AS-REP. Этот ответ содержит:
 - Сам билет TGT (зашифрованный ключом учетной записи krbtgt).
 - **Encrypted Part (enc-part):** Сессионный ключ и метаданные, зашифрованные долгосрочным ключом клиента (хэшем пароля).

Pre-auth критически важна: она заставляет клиента *сначала доказать владение ключом*, прежде чем KDC отдаст данные (AS-REP), которые могут быть использованы для офлайн-перебора.

Суть уязвимой конфигурации: Почему работает ASREPRoasting

Атака **AS-REP Roasting** становится возможной исключительно для тех аккаунтов Active Directory, у которых принудительно отключена опция «Требовать предварительную аутентификацию Kerberos» (в англоязычном интерфейсе — *Do not require Kerberos preauthentication / DoesNotRequirePreAuth*).

Техническая реализация отключения Pre-Auth

В базе данных LDAP Active Directory это состояние контролируется битовой маской атрибута `userAccountControl` (UAC). Флаг `DONT_REQ_PREAUTH` имеет десятичное значение 4194304 (или `0x00400000` в шестнадцатеричном формате). Если этот бит установлен, KDC меняет свое поведение.

Ошибка: Администраторы часто устанавливают этот флаг вручную для обеспечения совместимости со старыми приложениями (legacy), специфическими Linux-службами или кастомными скриптами, которые не умеют корректно обрабатывать сообщение `KRB5KDC_ERR_PREAUTH_REQUIRED`. Это фатальная ошибка архитектуры безопасности.

Если pre-auth отключена, любой субъект, имеющий сетевой доступ к контроллеру домена, может отправить AS-REQ от имени целевого пользователя (без зашифрованной временной метки) и сразу получить ответ AS-REP. Поскольку часть ответа AS-REP зашифрована хэшем пароля пользователя, атакующий получает идеальный криптографический материал для извлечения пароля методом перебора (брутфорса) на собственных мощностях.

Модель угроз и цели атакующего

Главная цель ASREPRoasting — получение сырого криптографического материала (хэшей/зашифрованных блоков) для офлайн-восстановления пароля (plaintext password). Успешная компрометация дает атакующему полные права жертвы во всех службах, доверяющих AD (интерактивный логон, RDP, почта, VPN, доступ к файловым шарам).

Приоритизация целей при проведении Red Team операций:

1. **Пользовательские и сервисные аккаунты с отключенной pre-auth:** Главная мишень. Часто это "технические" учетки, о которых забыли.
2. **Высокопривилегированные аккаунты:** Администраторы домена, Enterprise Admins, если им по ошибке, в ходе траблшутинга, отключили pre-auth.
3. **Аккаунты со статическими/слабыми паролями:** Сервисные аккаунты редко меняют пароли. Если пароль не менялся годами и не соответствует современным политикам сложности, офлайн-перебор займет минуты.

Риски: Главная опасность AS-REP Roasting в том, что весь процесс перебора пароля происходит **офлайн**, на GPU-фермах злоумышленника. В сети жертвы нет характерного шума от failed logons (событий с кодом 4625), следовательно, не срабатывает блокировка учетной записи (Account Lockout Policy).

Сравнение roasting-атак: AS-REP Roasting против Kerberoasting

Обе техники нацелены на Kerberos и преследуют цель извлечения материала для офлайн-перебора, но они эксплуатируют разные этапы протокола и разные конфигурационные особенности. Понимание разницы критично для построения правильной стратегии детекции.

Параметр	AS-REP Roasting	Kerberoasting
Цель запроса	Запрос первичного ответа сервера (AS-REP) на фазе обмена AS-REQ/AS-REP.	Запрос сервисного билета (TGS-REP) на фазе обмена TGS-REQ/TGS-REP.
Подверженные учетные записи	Любые учетные записи (пользователи или сервисы), у которых принудительно отключена Pre-Authentication.	Сервисные учетные записи, у которых установлен атрибут ServicePrincipalName (SPN).
Требуется намеренно или ошибочно отключенной опции (флаг DoesNotRequirePreAuth).	Работает в стандартной (дефолтной) доменной конфигурации. Достаточно иметь валидный TGT любого пользователя.	
Сетевые индикаторы (Логи)	Всплеск событий Event ID 4768 (AS-REQ) с параметром Pre-Authentication Type = 0.	Специфический поток событий Event ID 4769 (TGS-REQ) с типом шифрования 0x17 (RC4).

Жизненный цикл атаки AS-REP Roasting (Kill Chain)

Для успешного выполнения ASREPROasting, злоумышленнику обычно требуется реализовать несколько последовательных шагов. Даже низкопривилегированный доменный пользователь может инициировать эту атаку, что делает ее идеальной на пост-эксплуатационной фазе (после получения первой точки опоры — Initial Access).

1. Доступ в домен и разведка (Reconnaissance)

На первом этапе атакующий, уже имея любую валидную доменную учетную запись или доступ к машине в домене (со связью по порту 88/TCP к DC), проводит перечисление объектов каталога через протокол LDAP.

Цель разведки — найти аккаунты с атрибутом `userAccountControl`, включающим флаг `DONT_REQ_PREAUTH`.

Для этого часто используется штатный модуль PowerShell ActiveDirectory. Ниже приведен пример команды, который часто применяется как в инструментах аудита (BloodHound, PowerView), так и администраторами при проверке безопасности:

```
Get-ADUser -Filter * -Properties DoesNotRequirePreAuth |  
  Where-Object {$_.DoesNotRequirePreAuth -eq $True -and $_.Enabled -eq $True} |  
  Select-Object SamAccountName,DoesNotRequirePreAuth |  
  Sort-Object SamAccountName
```

Альтернативно, если штатный модуль недоступен, злоумышленники используют PowerView:

```
Get-DomainUser -PreauthNotRequired -Properties samaccountname,useraccountcontrol
```

2. Формирование AS-REQ без pre-auth

Как только список уязвимых пользователей (например, `svc_backup`, `legacy_admin`) сформирован, атакующий генерирует пакет Kerberos AS-REQ. В этом пакете намеренно опускается структура `padata` (Pre-Authentication Data). Поскольку контроллер домена видит, что для данной учетной записи эта проверка отключена, он не отправляет `KRB5KDC_ERR_PREAUTH_REQUIRED`, а переходит к генерации билета.

3. Извлечение и сохранение AS-REP хэшей

Контроллер домена формирует ответ AS-REP. Внутри этого ответа находится структура `enc-part`, которая зашифрована долгосрочным ключом пользователя (производным от его пароля). Инструменты атакующего перехватывают этот ответ, извлекают зашифрованный блок и форматируют его в структуру, понятную утилитам для взлома хэшей (Hashcat или John the Ripper).

Полученные строки обычно имеют префикс `$krb5asrep$`, и в подавляющем большинстве случаев (если не отключен RC4 в домене) шифруются алгоритмом RC4-HMAC.

4. Офлайн-перебор пароля (Cracking)

Извлеченные данные переносятся на вычислительную ферму (GPU). В зависимости от используемого алгоритма шифрования (Type 23 для RC4 или Type 18 для AES-256), скорость перебора может варьироваться. Для RC4 (режим 18200 в Hashcat) скорость на современных видеокартах достигает миллиардов комбинаций в секунду, что делает словарные пароли абсолютно беззащитными.

Пример синтаксиса для Hashcat

```
hashcat -m 18200 -a 0 hashes.asreproast rockyou.txt --force
```

Пример синтаксиса для John the Ripper

```
john --format=krb5asrep --wordlist=rockyou.txt hashes.asreproast
```

5. Использование полученных учетных данных

Восстановив пароль в открытом виде (plaintext), атакующий переходит к этапу Lateral Movement (горизонтальное перемещение). Полученный аккаунт может использоваться для:

- Аутентификации по RDP или WinRM на серверах инфраструктуры.
- Использования в техниках Pass-the-Hash / Pass-the-Ticket (если пароль не был вскрыт, но получен NT-hash).
- Реализации атак DCSync (если скомпрометирован аккаунт с правами Replicating Directory Changes).
- Дальнейшей разведки в защищенных сегментах сети.

Инструментарий атакующего: Чем реализуется AS-REP Roasting

Для автоматизации процесса поиска уязвимых учетных записей и извлечения AS-REP хэшей создано множество утилит. На практике в арсенале Red Team специалистов и злоумышленников доминируют два фреймворка: **Rubeus** (для работы в Windows-окружении) и **Impacket** (для атак из Unix-систем).

Rubeus (C# / .NET)

Rubeus — это мощнейший инструмент для взаимодействия с протоколом Kerberos, написанный на C#. Модуль `asreproast` автоматически выполняет LDAP-запросы для поиска пользователей без pre-auth, генерирует AS-REQ и извлекает хэши в нужном формате.

Ключевое преимущество Rubeus — возможность работы непосредственно из памяти (in-memory execution) через Cobalt Strike (с помощью execute-assembly) или другие C2-фреймворки, что затрудняет детекцию классическими антивирусами.

Практика: Примеры запуска Rubeus для различных сценариев:

```
# Базовый запуск: собрать хэши для всех уязвимых аккаунтов и сохранить в файл
Rubeus.exe asreproast /format:hashcat /outfile:C:\Temp\hashes.txt
```

```
# Точечная атака: запросить AS-REP только для конкретного пользователя (снижает сеть)
Rubeus.exe asreproast /user:legacy_svc /format:john
```

```
# Атака на определенное организационное подразделение (OU)
Rubeus.exe asreproast /ou:"OU=Service Accounts,DC=corp,DC=local" /format:hashcat
```

Impacket — GetNPUsers.py (Python)

Скрипт GetNPUsers.py из набора Impacket является стандартом де-факто для проведения AS-REP Roasting с машин под управлением Linux (например, Kali Linux). Он позволяет выполнять атаку удаленно, не требуя выполнения кода на скомпрометированном Windows-хосте.

Особенность скрипта в том, что он может использовать как авторизованный доступ (через учетную запись с известным паролем или хэшем), так и анонимный NULL-bind сеанс, если контроллер домена разрешает анонимные LDAP-запросы (что редкость в современных AD, но встречается в legacy-инфраструктурах).

```
# Атака с использованием валидных доменных учетных данных для LDAP-разведки
GetNPUsers.py corp.local/john.doe:Password123 -request -format hashcat -outputfile h
```

```
# Использование списка пользователей (если мы заранее собрали имена через перечислен
GetNPUsers.py corp.local/ -usersfile users.txt -no-pass -format john -outputfile has
```

```
# Использование Pass-the-Hash для авторизации LDAP-запроса
GetNPUsers.py corp.local/admin_user -hashes LMHASH:NTHASH -request -format hashcat
```

Детекция AS-REP Roasting и мониторинг событий безопасности

Обнаружение AS-REP Roasting требует комплексного подхода: от мониторинга сетевых аномалий до настройки гранулярного аудита на контроллерах домена. Главная сложность для защитников (Blue Team) заключается в том, что события, генерируемые атакой, легитимны с точки зрения протокола.

Журналы безопасности Windows (Event ID 4768)

Основным источником сигналов (Telemetry) являются журналы безопасности на контроллерах домена. При генерации билета TGT создается событие **Event ID 4768**

(«A Kerberos authentication ticket (TGT) was requested»).

Чтобы отличить легитимный запрос от атаки ASREPRoasting, SIEM-система должна коррелировать специфические поля этого события:

- Service Name (Имя службы): должно быть равно krbtgt.
- Pre-Authentication Type: имеет критическое значение **0** (или пустое поле в некоторых старых версиях ОС). Тип 0 означает, что KDC выдал билет без предварительной проверки подлинности. *Для сравнения: при легитимной pre-auth обычно используется тип 2 (PA-ENC-TIMESTAMP) или 15/16/17 для смарт-карт (PKINIT).*
- Ticket Encryption Type: часто указывает на 0x17 (RC4-HMAC), так как атакующие могут намеренно запрашивать понижение шифрования (Downgrade attack) для ускорения брутфорса.
- Client Address: IP-адрес источника. Аномалией считается запрос к сервисной учетной записи с IP-адреса рабочей станции, а не сервера, на котором этот сервис должен работать.

Логирование изменений атрибутов и LDAP-разведки

Продвинутая детекция включает отслеживание этапа подготовки к атаке.

Злоумышленник (или инсайдер) может намеренно отключить pre-auth для учетной записи перед проведением атаки (например, чтобы создать бэкдор).

Рекомендации: Настройте оповещения (Alerts) на следующие события в журнале безопасности контроллера домена:

- **Event ID 4738** (A user account was changed): Ищите изменения в поле User Account Control. Переход значения (например, с 0x200 NORMAL_ACCOUNT на 0x400200 NORMAL_ACCOUNT + DONT_REQ_PREAUTH) — это красный флаг.

- **Event ID 5136** (A directory service object was modified): Детализированный аудит изменений объекта в LDAP, позволяет увидеть точное изменение атрибута userAccountControl.

Также современные SIEM/NDR системы могут отслеживать **массовые LDAP-запросы**. Если хост отправляет специфический фильтр (userAccountControl:1.2.840.113556.1.4.803:=4194304) и перебирает весь каталог, это явный индикатор разведки (Reconnaissance).

Средства EDR/IDR и специализированные решения

Платформы класса Identity Threat Detection and Response (ITDR), такие как Microsoft Defender for Identity (MDI), имеют встроенные эвристические правила для блокировки

или алертинга «Suspected AS-REP Roasting attack». Они анализируют сетевой трафик (DPI для Kerberos) и выявляют:

- Отсутствие поля `padata` в пакетах AS-REQ.
- Следы автоматизированных инструментов (специфические заголовки, тайминги, отсутствие последующего TGS-REQ).

Honeypot-учетные записи (Cyber Deception)

Одним из самых элегантных и эффективных методов обнаружения AS-REP Roasting является использование "медовых горшков" (Honeypots).

Создается фиктивная учетная запись (например, `svc_sql_backup`). Ей принудительно устанавливается флаг `DoesNotRequirePreAuth`, назначается сверхсложный пароль (100+ символов), и генерируется несколько фиктивных логов. Легитимным системам этот аккаунт неизвестен. Следовательно, **любой** запрос AS-REQ (Event ID 4768) к этому аккаунту имеет 100% вероятность (True Positive), что в вашей сети работает злоумышленник или автоматизированный сканер.

Меры защиты и снижение риска (Hardening AD)

Защита от AS-REP Roasting тривиальна в теории, но сложна на практике в крупных Enterprise-сетях из-за "исторического наследия". Вот подробный чек-лист по устранению уязвимости.

1. Включение Pre-Auth для всех возможных учетных записей

Главное правило: `DoesNotRequirePreAuth` должно быть равно `$False`.

- Проведите аудит домена с помощью PowerShell (скрипт указан в начале статьи).
- Составьте список всех аккаунтов с отключенной пре-аутентификацией.
- Свяжитесь с владельцами сервисов. Если сервис поддерживает Kerberos Pre-Auth (а это делают 99.9% современных служб), снимите галочку в свойствах аккаунта (вкладка Account → Account Options → снять "Do not require Kerberos preauthentication").

2. Политика сильных паролей и управление секретами

Даже если уязвимый аккаунт найден, атака не увенчается успехом, если хэш невозможно взломать. Зачастую ASREPRoasting ломается об криптографию.

- Используйте пароли длиной не менее 16-25 символов для сервисных аккаунтов, сгенерированные менеджером паролей.

- Внедрите **gMSA (Group Managed Service Accounts)**. gMSA автоматически генерирует сложные пароли длиной 120 символов и меняет их каждые 30 дней. Брутфорс пароля gMSA математически невозможен в разумные сроки.
- Для учетных записей администраторов используйте аппаратные токены (Smart Cards, Windows Hello for Business), что меняет механику первичной аутентификации на PKINIT, исключая использование слабых паролей.

3. Минимизация и сегментация привилегий (Least Privilege)

Снижайте потенциальный ущерб (Blast Radius) от компрометации (Assume Breach):

- Сервисные учетные записи не должны состоять в группах Domain Admins.
- Используйте концепцию Tier-моделирования (Tier 0, Tier 1, Tier 2). Учетная запись из Tier 2 не должна иметь прав на вход (Logon) на серверы Tier 0 (Контроллеры домена, PKI).

Ошибка: Оставлять старые учетные записи (legacy) с высокими привилегиями активными только потому, что «никто не знает, что сломается, если их отключить». Это прямой путь к полному захвату леса (Domain Compromise) злоумышленниками-шифровальщиками (Ransomware).

4. План реагирования (Incident Response)

При получении оповещения от SIEM об успешном AS-REP Roasting немедленно:

1. Изолируйте хост, с которого производились AS-REQ запросы (он скомпрометирован).
2. Заблокируйте и сбросьте пароли для всех учетных записей, которые подверглись "ростингу". *Обратите внимание: пароль нужно менять дважды, чтобы очистить историю хэшей в Kerberos-билетах.*
3. Выполните поиск (Threat Hunting) по логам 4624 (Logon) с использованием скомпрометированных аккаунтов, чтобы определить, успел ли атакующий применить взломанные пароли.

Современные тренды и практические кейсы (2024–2026 гг.)

Несмотря на то, что механика AS-REP Roasting была детально задокументирована исследователями ИБ еще в середине 2010-х годов (вместе с ростом популярности BloodHound и Rubeus), эта техника продолжает активно применяться в реальных кибератаках. Ошибки конфигурации в гибридных средах (On-Premise + Cloud Azure AD / Entra ID) и легаси-сервисах оставляют широкое поле для деятельности.

Кейс BlackSuit (2024 год): В отчетах DFIR-команд (Digital Forensics and Incident Response) за 2024 год отмечалось, что группировка вымогателей BlackSuit активно

использовала комбинацию AS-REP Roasting и Kerberoasting для эскалации привилегий. Получив первоначальный доступ через уязвимый VPN-шлюз, злоумышленники собрали AS-REP хэши нескольких технических учетных записей (отвечающих за резервное копирование). Из-за слабого пароля (словарный пароль + год) перебор занял менее 20 минут. Полученный пароль дал им права локального администратора на критичных серверах, откуда они развернули шифровальщик с помощью групповых политик (GPO).

Аудиторские стандарты (2025-2026 гг.):

Современные гайды по hardening Active Directory от агентств альянса Five Eyes (CISA, NCSC) включают явную проверку на наличие пользователей с флагом DoesNotRequirePreAuth. Сегодня нахождение даже одной такой высокопривилегированной учетки при аудите считается критической уязвимостью (Severity: Critical).

Вывод

AS-REP Roasting — это классический пример того, как базовая легитимная функция протокола может быть использована против самой системы в случае ошибки конфигурации. В отличие от эксплуатации уязвимостей нулевого дня (0-day) или повреждения памяти, эта техника не вызывает сбоев систем и остается невидимой для классических антивирусов.

Для атакующего это бесшумный и надежный способ получения криптографического материала для брутфорса. Для защитника это явный маркер технического долга в инфраструктуре. Единственный надежный способ защиты заключается в проактивном аудите каталога Active Directory, включении Kerberos pre-authentication для всех без исключения аккаунтов, использовании gMSA-аккаунтов для сервисов и настройке жесткого мониторинга событий 4768.

Частые вопросы (FAQ)

1. Что такое pre-authentication в Kerberos и зачем она нужна?

Pre-authentication (предварительная аутентификация) — это защитный механизм в Kerberos. Он требует, чтобы клиент, запрашивающий билет TGT, доказал знание своего пароля путем шифрования текущей временной метки (timestamp) своим хэшем пароля. Это предотвращает возможность запросить ответ сервера (AS-REP), содержащий материал для офлайн-взлома пароля, кем угодно.

2. Можно ли провести AS-REP Roasting без действующей учетной записи в домене?

Как правило, нет. Для получения списка учетных записей с отключенной пре-аутентификацией требуется возможность выполнять LDAP-запросы, что в большинстве современных доменов требует наличия хотя бы низкопривилегированной доменной учетной записи. Однако, если злоумышленник уже знает имя уязвимого пользователя (например, угадал его или нашел в открытых источниках), он может отправить AS-REQ без LDAP-разведки. В крайне редких случаях, когда разрешен Anonymous LDAP Bind, атаку можно провести без логина и пароля.

3. Почему для AS-REP Roasting часто запрашивают RC4, а не AES?

Алгоритм RC4 (тип шифрования 0x17 или 23) криптографически значительно слабее, чем AES-128 или AES-256 (типы 17 и 18). Хэши, зашифрованные с помощью RC4, подбираются (брутфорсятся) на GPU в сотни и тысячи раз быстрее. Злоумышленники используют инструменты вроде Rubeus для намеренного запроса RC4, если он не отключен на уровне контроллера домена (Downgrade Attack).

4. Поможет ли внедрение MFA (многофакторной аутентификации) для защиты от этой атаки?

Само по себе отключение Pre-Auth часто конфликтует со строгими политиками смарт-карт и современным MFA. Если злоумышленник сбрутил пароль от уязвимого аккаунта, но в домене строго настроен доступ к критичным сервисам только по сертификатам (PKI) или MFA, он не сможет интерактивно залогиниться. Однако он все равно получит валидный NT-hash для выполнения атак типа Pass-the-Hash на legacy-протоколы (например, NTLM через SMB).

5. В чем главное отличие логов AS-REP Roasting от Kerberoasting?

Визуально в SIEM они различаются по Event ID и полям. AS-REP Roasting генерирует всплеск событий **4768** (AS-REQ) с Pre-Authentication Type = 0 и Service Name = krbtgt. Kerberoasting генерирует события **4769** (TGS-REQ) на конкретные Service Principal Names (SPN) с типом шифрования билета RC4 (0x17).

6. Как быстро найти все уязвимые аккаунты в лесу Active Directory?

Вы можете использовать встроенный модуль PowerShell ActiveDirectory и выполнить команду: `Get-ADUser -Filter {DoesNotRequirePreAuth -eq $True -and Enabled -eq $True} -Properties DoesNotRequirePreAuth`. Также этот параметр автоматически проверяется утилитами для анализа защищенности, такими как BloodHound (вычисляя пути до уязвимых узлов) и PingCastle.

7. Стоит ли автоматически блокировать аккаунты при обнаружении атаки AS-REP Roasting?

Автоматическая блокировка может привести к отказу в обслуживании (Denial of Service), так как атакующий может намеренно генерировать AS-REQ запросы от имени важных сервисов, чтобы парализовать работу компании. Лучшей практикой является детальное расследование: изоляция источника запросов (IP атакующего), мануальный анализ, и затем плановая смена пароля с последующим включением Pre-Auth.